Glossary

Plain-language definitions of the product security terms used in the course, in alphabetical order, and where to read further.

These are practical summaries, not regulatory text. For regulatory terms, the source document and your regulatory team govern. Regulatory details are current as of October 2026.

AAMI SW96 · ANSI/AAMI SW96:2023, the FDA-recognized standard for device security risk management. It runs alongside ISO 14971, so security risks that could harm patients reach the safety risk file.

AAMI TIR57 and TIR97 · Technical reports on security risk management (TIR57, largely replaced by SW96 in practice) and on postmarket security risk (TIR97).

AI Act · The EU's AI law. For AI in devices it requires accuracy, robustness and cybersecurity, including resistance to poisoned data; device deadlines moved to 2028.

Architecture views · Diagrams of a product's components, connections, data flows and trust boundaries, showing where security controls sit. FDA expects them in a submission.

Attack surface · Every place an attacker could try to get in: ports, radios, apps, services, update paths. Minimize it by removing what the product doesn't need.

Authentication · Checking who or what is connecting, such as a clinic programmer proving itself to an implant.

Authorization · Checking what an authenticated person or system is allowed to do.

Availability · The security property that a device and its functions work when needed. For a therapy device, this means availability of therapy.

CISA · The US Cybersecurity and Infrastructure Security Agency. It coordinates some disclosures, publishes advisories and runs the voluntary Secure by Design principles and pledge.

Compensating controls · Measures that reduce risk when the preferred control or a patch isn't possible, such as isolating an unpatchable device on its own network segment.

Confidentiality · The security property that only the right people and systems can see the data, such as patient images or heart-rhythm reports.

Controlled risk · In FDA's 2016 postmarket guidance, a vulnerability whose residual risk of patient harm is acceptable. Fixed in a routine update; generally not reported as a correction.

Coordinated vulnerability disclosure (CVD) · Researcher and manufacturer, sometimes with a government coordinator, agree on timing so a fix or mitigation is ready when an issue becomes public.

Corrective and preventive action (CAPA) · The quality-system process for investigating problems, fixing their causes and preventing recurrence. Security findings feed into it.

CVSS · Common Vulnerability Scoring System: a widely used severity score. FDA qualified a MITRE rubric that adapts it to clinical context.

Cyber device · Under Section 524B, a device that includes software, can connect to the internet, and could be vulnerable to cyber threats. FDA reads connectivity broadly.

Cyber Resilience Act (CRA) · EU regulation on the security of digital products. It excludes MDR/IVDR devices but reaches suppliers' components, gateways and non-medical accessories.

Defense in depth · Several independent layers of protection, so that if one fails the next still protects the patient.

Design controls · The quality-system process for planning, reviewing, verifying and validating a design. Security is added to it, not run separately.

Design for updates · Planning from day one how fixes will reach every device safely for its whole service life.

End of support · When a manufacturer stops providing support, including security updates. Plan it from design and announce it early. (End of life: it stops selling the product.)

Enterprise IT security · Protecting an organization's own computers, networks and data. Product security protects what the company sells.

Exploitability · How easy a weakness is to use, given the access, skill and tools needed. Security risk is rated by exploitability and severity, not probability.

Fail safe · When something goes wrong, the device falls back to a state that keeps the patient safe, rather than locking up.

FDA · The US Food and Drug Administration, the regulator for medical devices. Its cyber expectations come from law (Section 524B), regulation (the QMSR) and guidance.

General safety and performance requirements (GSPRs) · Annex I requirements of the EU MDR and IVDR. They include information security in software, minimum IT security requirements and protection against unauthorized access.

Guidance · A regulator's written expectations: how it reads the law and what reviewers look for. Not legally binding, but it is what reviewers check.

Hazard and hazardous situation · A hazard is a potential source of harm; a hazardous situation is when a patient is exposed to one. Security adds a new cause: a hazard triggered on purpose.

Health Sector Coordinating Council (HSCC) · Healthcare industry council. Its Joint Security Plan (JSP2) is a secure-by-design framework; its Model Contract (MC2) splits cyber duties between manufacturers and providers.

IEC 62443-4-1 and 4-2 · Industrial standards for secure development (4-1) and component security requirements (4-2), often used to support device security claims.

IEC 81001-5-1 · The international standard (2021) for security activities across the health software lifecycle. FDA-recognized; Japan's identical JIS T 81001-5-1 is its accepted route.

Incident response · Handling an actual or suspected attack on a product in the field: contain it, check patient safety, restore a known good state, learn from it.

Information Sharing and Analysis Organization (ISAO) · A group where manufacturers, hospitals and others share threat information, such as Health-ISAC. Membership is one condition for FDA's lighter postmarket reporting.

Integrity · The security property that data, settings, software and commands can't be changed without authorization. Often the most important property for therapy devices.

Interim measures · Temporary steps, such as restricting a connection or disabling a feature, that protect patients while a full fix is prepared and validated.

International Medical Device Regulators Forum (IMDRF) · Where device regulators agree shared principles. Its 2020 cybersecurity principles are the baseline national rules borrow from.

ISO 13485 · The quality management system standard for medical devices. The US QMSR incorporates it, so it is binding for devices sold in the US.

ISO 14971 · The standard for medical device safety risk management. Its scope explicitly includes data and systems security.

ISO/IEC 29147 and 30111 · Standards for vulnerability disclosure (receiving and publishing) and vulnerability handling (investigating and fixing). Most PSIRT processes build on them.

Labeling · Security information for customers: secure setup, network requirements, how updates arrive, the support period. In the EU, minimum IT security requirements go in the instructions for use.

Least privilege · Every person and component gets only the access it needs, like a hotel key card that opens only your room.

Legacy device · A device that can no longer be reasonably protected against current threats but is often still in clinical use. Managing it is a shared responsibility.

MDCG 2019-16 · The EU's non-binding guidance on cybersecurity for medical devices (Rev.1, 2020). It explains how to meet the GSPRs.

MDR and IVDR · The EU Medical Device Regulation and In Vitro Diagnostic Regulation. Their GSPRs include cybersecurity; a proposed revision would make it explicit.

MDS2 · Manufacturer Disclosure Statement for Medical Device Security: a standard form hospitals use to compare devices. A customer expectation, not a regulation.

Multi-factor authentication (MFA) · Requiring a second proof of identity beyond a password, for example for remote service sessions.

Multi-patient harm · Harm to many patients at once from one weakness in shared infrastructure, such as a cloud portal, update server or drug library.

NIS2 Directive · EU law on the cybersecurity of organizations, including device manufacturers above size thresholds. About the company's own security and incident reporting, not the product.

Penetration testing · Skilled testers trying to break in as an attacker would, to find weaknesses before release.

Postmarket · A product's working life after release, usually the longest phase: monitor, assess patient risk, fix, tell customers, report when required.

Premarket · Everything before a product is authorized and sold: designing security in, threat modeling, testing, and preparing evidence for the submission.

Privacy · Protecting people's personal information and how it is used. It overlaps with product security but is a separate job.

Product security · Making sure a product and everything it depends on can resist, detect and recover from attacks while in use. A product security program makes it routine.

Product security incident response team (PSIRT) · The team that receives and handles vulnerability reports and security incidents for products: triage, fixes, disclosure and communication.

Quality management system · A manufacturer's procedures for designing, making and maintaining products: design controls, risk management, supplier controls, complaints, CAPA.

Quality Management System Regulation (QMSR) · FDA's quality regulation, effective February 2026, which incorporates ISO 13485. No cyber clause, but FDA maps security work onto its processes.

RACI chart · For each activity: who is Responsible (does the work), Accountable (owns the outcome; exactly one role), Consulted and Informed.

Ransomware · Malicious software that locks or encrypts systems until a ransom is paid. Devices can be hit as collateral damage.

Regulator reporting · Telling a regulator about a security issue when the rules require it. Under FDA policy, fixing an uncontrolled risk is generally reportable; your regulatory team decides.

Residual risk · The risk that remains after controls are in place.

Safety risk management · Identifying hazards, estimating the risk of harm, controlling it and checking the controls work, following ISO 14971.

Section 524B · The part of the US FD&C Act, in force since March 2023, requiring cyber device submissions to include a postmarket vulnerability plan, secure update processes and an SBOM.

Secure by default · Ship in the safest configuration, so customers opt in to riskier options: remote service off, no shared factory password.

Secure by design · Treating security as a property of the design from the first sketch. Also the name of CISA's voluntary principles and pledge for software vendors.

Secure Product Development Framework (SPDF) · FDA's term for processes, built into the quality system, that bring security into every phase of development and keep it going after release.

Secure Software Development Framework (SSDF) · NIST's voluntary good practice for secure software development.

Security control categories · FDA's design checklist: authentication, authorization, cryptography, integrity, confidentiality, event detection and logging, resiliency and recovery, updatability.

Security incident · An event in which a weakness is, or may have been, exploited. Report suspected incidents right away; you don't need to be sure.

Security questionnaire · A customer's list of security questions about a product. Answer from approved documentation; route new questions to product security.

Security requirements · Testable requirements that answer significant threats, such as “remote service sessions shall require multi-factor authentication.”

Security researcher · An independent person who finds and reports vulnerabilities. Treat them as partners: point them to the disclosure policy and tell the PSIRT.

Security risk management · Identifying threats and weaknesses, rating exploitability and severity, and choosing controls. Separate from, but linked to, safety risk management.

Shared responsibility · Manufacturers, hospitals and others each own part of a device's security. A hospital can't patch unvalidated software; a manufacturer can't segment a hospital's network.

Signed update · An update with a digital signature the device checks to confirm it came from the manufacturer unaltered. Signing protects integrity, not secrecy.

Software bill of materials (SBOM) · The product's ingredients list: every software component with name, version, supplier and support status. Required in US cyber device submissions.

SPDX and CycloneDX · The two most common machine-readable SBOM formats.

Standard · A consensus document from a body such as ISO, IEC or AAMI that says how. Voluntary, but regulators often recognize standards. Frameworks are similar good practice from industry groups or agencies.

Supplier controls · Quality-system processes for managing suppliers. For security: component lists, vulnerability notification and support life in contracts.

Third-party software · Software written by someone else: commercial, open-source or other off-the-shelf components. You inherit its weaknesses; it belongs in the SBOM.

Threat · Someone or something that could exploit a weakness to cause harm: the start of the chain from threat to harm.

Threat modeling · A structured team look at a design: how does it work, what could someone do to it on purpose, and what will we do about it?

Total product lifecycle (TPLC) · Every stage of a device's life, from first design idea until the last unit leaves service.

Traceability · Links from each threat to its control, the test that verifies it, and the residual risk.

Trade-offs · Balancing security against usability, emergency access, clinical workflow, performance and validation burden, with clinical input and the rationale recorded.

Uncontrolled risk · In FDA's 2016 postmarket guidance, a vulnerability whose residual risk of patient harm is unacceptable. Needs prompt fixes and communication, and is generally reportable.

Verification and validation · Checking that a design meets its requirements and that the device meets user needs. Every change, including a security fix, goes through it.

VEX · Vulnerability Exploitability eXchange: statements telling customers whether a known vulnerability in a listed component actually affects the product.

Vulnerability · A weakness someone could exploit to cause harm.

Vulnerability disclosure policy (VDP) · A manufacturer's published statement telling researchers how to report a flaw and what to expect.

Vulnerability monitoring · Comparing the SBOM with vulnerability databases and supplier advisories, so the team learns quickly when a shipped component has a known flaw.

Further reading · primary sources; check the publisher for the current version

US FDA, premarket cybersecurity guidance
Cybersecurity in Medical Devices: Quality Management System Considerations and Content of Premarket Submissions (2023; updated 2025; reissued 2026). What FDA expects before release, including the Section 524B requirements. `fda.gov`

US FDA, postmarket cybersecurity guidance
Postmarket Management of Cybersecurity in Medical Devices (2016). Monitoring, assessing and responding to vulnerabilities after release; controlled and uncontrolled risk. `fda.gov`

IMDRF principles
Principles and Practices for Medical Device Cybersecurity (2020), plus 2023 documents on legacy devices and SBOMs. The international baseline. `imdrf.org`

IEC 81001-5-1:2021
Health software and health IT systems safety, effectiveness and security, Part 5-1: Security, Activities in the product life cycle. The secure lifecycle standard for health software.

ANSI/AAMI SW96:2023
Standard for medical device security: Security risk management for device manufacturers. Security risk management alongside safety risk. `aami.org`

ISO 14971:2019
Medical devices: Application of risk management to medical devices. The safety risk process that security risk links to. `iso.org`

NIST SSDF
SP 800-218, Secure Software Development Framework. Secure development practices for any software team. `csrc.nist.gov/projects/ssdf`

CISA Secure by Design
Voluntary principles and pledge for software vendors generally; good for leadership conversations. `cisa.gov/securebydesign`

Go deeper with your team

This guide accompanies the free course **Product Security in One Hour** (mjhillyer.github.io/Product-Security-in-One-Hour). For in-depth, instructor-led product security training for your teams, with exercises on your own products and MedTech regulatory depth, contact **Matt Hillyer LLC** at **matt@matthillyer.io**. To see where your program stands, try the Product Security Maturity Framework scorecard (mjhillyer.github.io/Product-Security-Maturity-Assessment-Program/scorecard.html).